UNIVERSIDAD TECNOLÓGICA DE QUERÉTARO

Nombre de los integrantes:

Elian Eduardo Ramírez Ramírez

Grupo:

IDGS17

Nombre de la actividad:

FORMATO DE AVANCES

Nombre de la materia:

Desarrollo para dispositivos inteligentes

Labandera — Sitio web de noticias con API REST y autenticación de dos pasos (2FA/TOTP)

Plataforma de noticias (frontend React + Vite + Tailwind, backend Express + Prisma/PostgreSQL) que incorpora un sistema de autenticación de dos pasos basado en TOTP (RFC 6238), compatible con aplicaciones autenticadoras en dispositivos móviles.

2. Punto de partida (contexto del curso anterior)

Durante el cuatrimestre anterior se construyó el proyecto completo. Ese avance no forma parte del plan de avances de este ciclo: el tiempo del plan corre únicamente desde las nuevas implementaciones del sistema de autenticación de dos pasos.

Estado al cierre del curso anterior (referencia):

- Backend (API Express + Prisma): autenticación JWT, RBAC (lector, editor, administrador), gestión de artículos/categorías/imágenes, schemas de validación, middlewares, rate limiting, helmet, tests automatizados (vitest + supertest).
- Frontend (SPA React): páginas de noticias, login/registro, estadísticas con `AdminGuard`, accesibilidad, upload.
- Documentación: pruebas manuales (`docs/pruebas-manuales.md`), pruebas RBAC (`docs/pruebas-rbac.md`), diagrama de autenticación (`docs/mer-auth.mmd`), reportes de prácticas.

El plan de este ciclo parte de esa base funcional y se centra exclusivamente en la implementación del 2FA.

3. Justificación

El sistema actual de autenticación se basa únicamente en contraseña + JWT. Una contraseña comprometida (reúso, filtración, ingeniería social) da acceso total a la cuenta, y los administradores/editores manejan contenido sensible.

Implementar autenticación de dos pasos (2FA) con TOTP es necesario porque:

1. Mitiga el robo de credenciales: aunque la contraseña se filtre, el atacante necesita el segundo factor (código TOTP del dispositivo).
2. No depende de SMS ni correo: evita costos de mensajería, interceptación de SMS y dependencia de proveedores externos; funciona offline.
3. Estándar de la industria: TOTP (RFC 6238) es el mecanismo usado por la mayoría de plataformas (Google, GitHub, etc.), lo que reduce la curva de adopción del usuario.
4. Recuperación de acceso: los códigos de respaldo (hash, de uso único) permiten recuperar la cuenta si se pierde el dispositivo.
5. Endurecimiento: rate limiting en la verificación y registro de auditoría de intentos reducen el riesgo de fuerza bruta sobre códigos de 6 dígitos.

El alcance se limita a TOTP opt-in con recomendación; MFA por SMS/correo y "recordar este dispositivo" quedan fuera de este ciclo.

4. Selección de smart device

Aspecto	Selección	Justificación
Dispositivo	Smart watch (Android Wear / Wear OS o Apple Watch)	Es el smart device que el usuario ya posee y usa a diario; es el medio natural para el segundo factor.
Aplicación	App autenticadora TOTP disponible para smart watch (p. ej., Aegis, Authy o la app autenticadora nativa del reloj)	Genera los códigos de 6 dígitos localmente (RFC 6238), sin conexión a internet ni costo.
Interacción con el proyecto	El usuario escanea un QR Code (renderizado en el frontend con `qrcode.react`) desde la cámara del smart watch para registrar el secreto TOTP, e ingresa el código generado en la pantalla de login.	Cierre del flujo completo: navegador (frontend) ↔ API (backend) ↔ smart watch (segundo factor).
Criterios de selección	Uso diario y portabilidad permanente, bajo costo, offline, estándar abierto (TOTP), sin dependencia de proveedor.	Garantiza que cualquier usuario pueda activar 2FA sin hardware adicional.

El smart watch actúa como dispositivo de segundo factor, no como plataforma de despliegue: la aplicación se sigue usando desde el navegador, y el smart device aporta el código TOTP.

5. División de entregables en 3 fases

Los 8 entregables originales (H1–H8) se reagrupan en 3 fases, cada una con su hito de cierre y evidencia (incluye espacios para capturas de pantalla de las funciones de la aplicación del smart watch).

Fase	Alcance	Entregables originales	Hito de cierre
Fase 1 — Diseño y backend del 2FA	Diseño técnico, modelo de datos, endpoints de configuración y login de dos pasos en el backend	H1, H2, H3	Backend de 2FA completo y testeado
Fase 2 — Frontend y smart watch	Página de seguridad, login de dos pasos en el navegador y app autenticadora en el smart watch (Wear OS)	H4, H5	Experiencia de usuario 2FA completa (setup + login + desactivación)
Fase 3 — Pruebas, documentación y producción	Tests de integración, endurecimiento, documentación, deploy y estabilización	H6, H7, H8	2FA estabilizado en producción y documentado

Fase 1 — Diseño y backend del 2FA

Actividades:

1. Diseño y preparación

Diseño técnico: modelo de datos (User.totpSecret / totpEnabled / totpEnabledAt, tabla TotpBackupCode), endpoints y diagrama docs/mer-2fa.mmd.

Rama feat/2fa-foundation; instalar otplib (backend) y qrcode.react (frontend); revisar rate limits.

Checklist de pruebas manuales 2FA.

Hito H1: diseño aprobado y base técnica lista.

2. Modelo de datos y configuración 2FA (backend)

Migración de Prisma (campos en User + TotpBackupCode).

Endpoints: POST /api/auth/totp/setup, POST /api/auth/totp/verify-setup, DELETE /api/auth/totp, POST /api/auth/totp/backup-codes + middleware requireTwoFactorConfig.

Hito H2: backend de configuración 2FA completo y testeado.

3. Login de dos pasos (backend)

POST /api/auth/login con token pendiente + requires2fa; POST /api/auth/login/verify-2fa (TOTP o código de respaldo de uso único).

Rate limiting en verify-2fa y registro de auditoría (AuthAttempt).

Hito H3: login de dos pasos operativo en backend.

Hito de cierre de la fase:

H1 + H2 + H3: el backend genera el secreto TOTP y el QR, valida el código del segundo paso (TOTP o respaldo de uso único), aplica rate limiting y registra auditoría de intentos.

Evidencia:

Captura: diagrama de autenticación 2FA (docs/mer-2fa.mmd renderizado).

Captura: migración de Prisma aplicada (campos en User + tabla TotpBackupCode).

Captura: respuesta de POST /api/auth/totp/setup (secreto Base32 + URI otpauth://).

Captura: verificación de endpoint con curl/Postman (código correcto e incorrecto).

Captura: registro de auditoría (AuthAttempt) en la base de datos.

Fase 2 — Frontend y smart watch

Actividades:

1. Frontend: configuración del 2FA

Página /security: activar 2FA con QR Code, secreto en texto y códigos de respaldo (visible una vez); confirmación con código de 6 dígitos.

Servicios HTTP (setupTotp, verifyTotpSetup, disableTotp, regenerateBackupCodes) y hook useTwoFactor con manejo de errores.

Hito H4: frontend de configuración 2FA funcional.

2. Frontend: login de dos pasos

Paso 2 en la pantalla de login: campo de código de 6 dígitos, opción de código de respaldo, "olvidé mi dispositivo".

Token pendiente en memoria (no localStorage); desactivación de 2FA desde la sección de seguridad (con contraseña).

Hito H5: experiencia de usuario 2FA completa (setup + login + desactivación).

3. App del smart watch (Wear OS) — segundo factor

App autenticadora TOTP (wear-app): escaneo del QR de /security, guardado local del secreto, generación del código de 6 dígitos cada 30 s (RFC 6238, HmacSHA1) con countdown.

Funciones auxiliares: botón Restablecer (borra el secreto para escanear de nuevo) e Ingresar secreto manualmente (pegar el secreto Base32 sin escanear el QR).
Validación en el emulador de Wear OS (cámara virtual): escaneo del QR generado por el sitio y lectura del código en el login de la web.

Hito de cierre de la fase:

H4 + H5 (+ app del smart watch): el usuario puede activar 2FA desde el navegador (QR escaneado con el smart watch), loguearse en dos pasos leyendo el código en el reloj, usar un código de respaldo y desactivar el 2FA con contraseña.

Evidencia — Capturas de pantalla de las funciones de la app del smart watch:

Insertar aquí las capturas de pantalla de la aplicación del smart watch (Wear OS, wear-app):

Captura 1 — Escaneo del código QR desde la cámara del smart watch



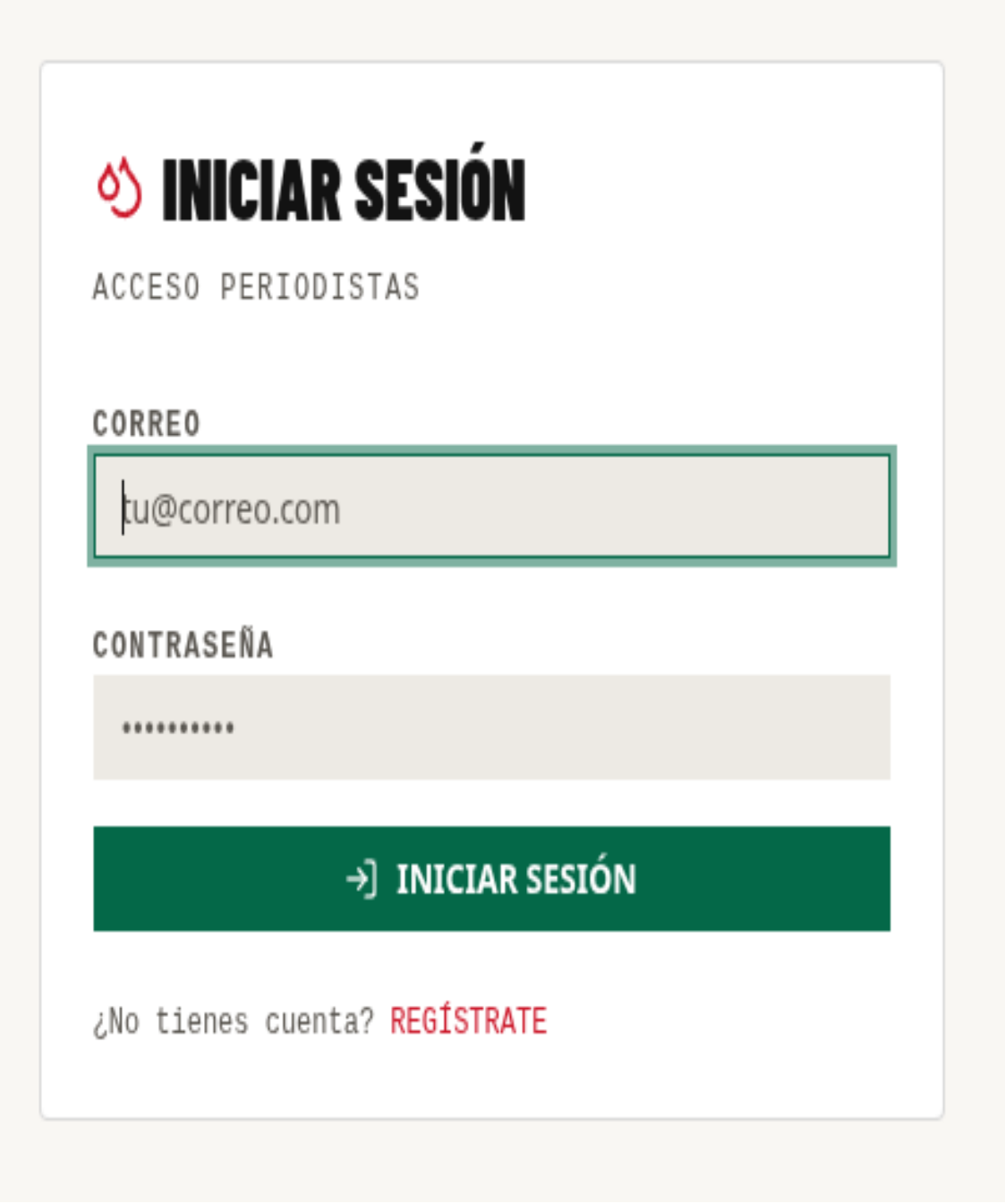
Captura 2 — Código de 6 dígitos mostrado en el smart watch (con countdown)



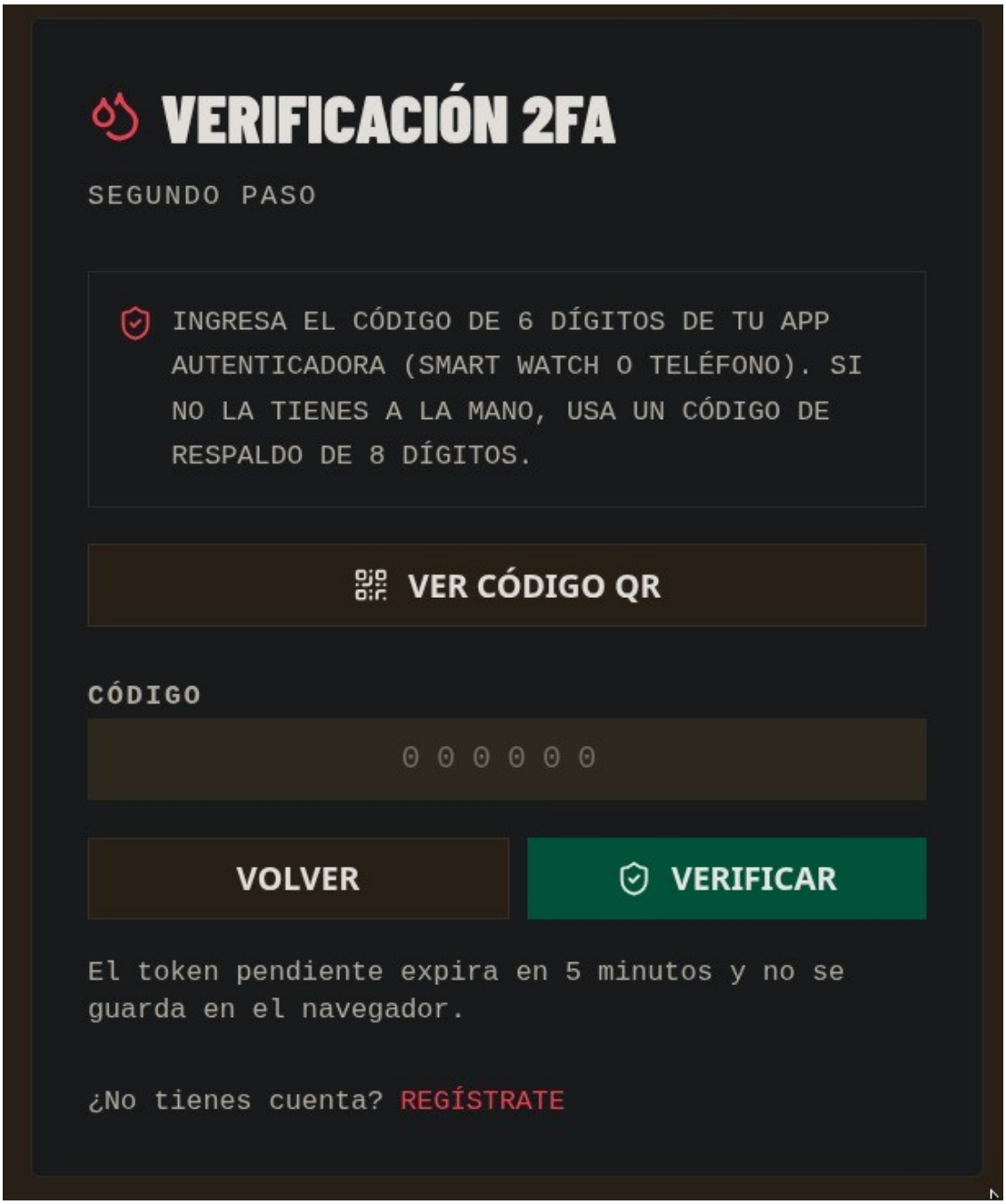
Captura 3 — Función de restablecer / desvincular el reloj


Código de verificación 2FA
admin@labandera.mx
056006
Se renueva en 22 s
Restablecer

Captura 5 — Confirmación del 2FA en la página /security de la web

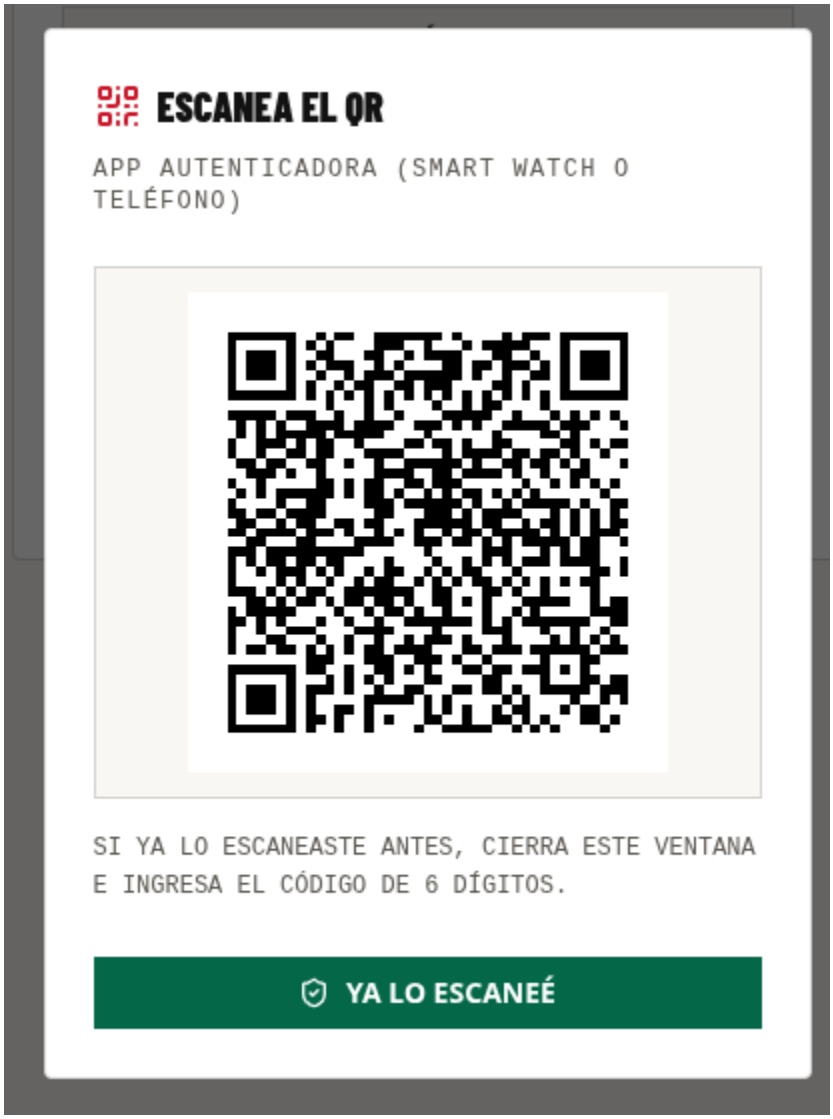


Captura 6 — Pantalla de login con el segundo paso (código del smart watch)


VERIFICACIÓN 2FA
SEGUNDO PASO
INGRESA EL CÓDIGO DE 6 DÍGITOS DE TU APP AUTENTICADORA (SMART WATCH O TELÉFONO). SI NO LA TIENES A LA MANO, USA UN CÓDIGO DE RESPALDO DE 8 DÍGITOS.
VER CÓDIGO QR
CÓDIGO
0 0 0 0 0 0
VOLVER
VERIFICAR
El token pendiente expira en 5 minutos y no se guarda en el navegador.
¿No tienes cuenta? REGÍSTRATE

Evidencia complementaria:

Captura: página /security con el QR Code renderizado (qrcode.react).



Captura: códigos de respaldo visibles una sola vez tras la activación.

SEGURIDAD

AUTENTICACIÓN EN DOS PASOS (TOTP)

GUARDA ESTOS 10 CÓDIGOS DE RESPALDO EN UN LUGAR SEGURO. SE MUESTRAN UNA SOLA VEZ Y CADA UNO SIRVE UNA SOLA VEZ.

01011539	60235051
30185087	52063797
47894270	16869583
04821816	96769957
94456105	40397885

COPIAR TODOS

LISTO

El token pendiente de 2FA nunca se guarda en el navegador.

Captura: desactivación de 2FA desde la sección de seguridad (con contraseña).



Fase 3 — Pruebas, documentación y producción

Actividades:

1. Pruebas y endurecimiento

Tests de integración (vitest + supertest): login con/sin 2FA, código correcto/incorrecto/expirado, respaldo válido/usado, setup con/sin autorización, rate limit (429).

Revisión de seguridad: secreto ofuscado, respaldos en hash, token pendiente no persistido, validación con zod, sin logs de secretos/códigos.

Hito H6: sistema probado y endurecido.

2. Documentación y puesta en producción

Actualizar README.md; crear docs/2fa.md (guía de usuario); actualizar pruebas-manuales.md; diagrama final docs/mer-2fa.mmd.

Migración en producción, build y deploy de backend y frontend; verificación end-to-end en producción.

Hito H7: 2FA en producción y documentado.

3. Estabilización y cierre

Monitoreo de intentos de autenticación, corrección de bugs, ajuste de rate limits.

Retrospectiva del ciclo y backlog para el siguiente (MFA SMS/email, "recordar este dispositivo").

Hito H8 (final): 2FA estabilizado en producción.

Hito de cierre de la fase:
H6 + H7 + H8: en producción, un usuario puede activar 2FA por QR (escaneado con el smart watch), loguearse con contraseña + TOTP, recuperar acceso con código de respaldo y desactivar el 2FA; todo cubierto por tests, documentación y monitoreo.
Evidencia:

- Captura: resultados de los tests de integración (vitest + supertest).
- Captura: respuesta 429 por rate limit en verify-2fa.
- Captura: documentación docs/2fa.md y README.md actualizados.
- Captura: verificación end-to-end en producción (activación, login 2FA, respaldo, desactivación).
- Captura: panel/consulta de auditoría de intentos en producción.

Resumen ejecutivo de hitos

Fase	Hito	Entregable
1	H1	Diseño técnico aprobado, dependencias listas
1	H2	Endpoints backend de configuración 2FA
1	H3	Login de dos pasos en backend
2	H4	Frontend de configuración 2FA (QR + setup)
2	H5	Frontend de login 2FA + desactivación
2	—	App del smart watch (Wear OS) como segundo factor
3	H6	Pruebas automatizadas + endurecimiento
3	H7	Documentación + despliegue a producción
3	H8	Estabilización y cierre del ciclo

1. Preguntas

¿Cuál es el tipo de almacenamiento estructurado que voy a utilizar para almacenar la información en el servidor?

base de datos relacional (PostgreSQL)

- **usuarios**: id, nombre, correo, hash de contraseña (bcrypt o argon2), rol (lector, editor, admin).
- **dispositivos_2fa**: id, usuario_id, identificador del smartwatch, secreto TOTP **cifrado**, fecha de vinculación, estado (activo o revocado).
- **desafios_2fa**: usuario_id, código o token (guardado como hash), expiración, intentos, estado. Si el flujo es por push al reloj, aquí se registra la aprobación o el rechazo.
- **sesiones**: token, usuario_id, dispositivo, IP, expiración.
- **auditoria_accesos**: intentos exitosos y fallidos con fecha e IP.
- **articulos, categorias, archivos_multimedia**: el contenido editorial y la metadata de los archivos.

¿Qué tipo de archivos multimedia, ZIP RAR va a poder almacenar y gestionar?

Imágenes en formato estándar de acuerdo a los dispositivos usados de forma general en la profesión.

Tipo	Formatos recomendados	Notas
Imágenes	JPG, PNG, WebP, AVIF	Genera miniaturas y versiones optimizadas.
Comprimidos	**ZIP** (sí, con controles)	Por ejemplo galerías o paquetes de prensa.

¿Dónde vas a guardar la información y por qué?

Base de datos relacional PostgreSQL en servidor en la nube.

¿Cómo aplicar las pirámide testing en mi proyecto?